

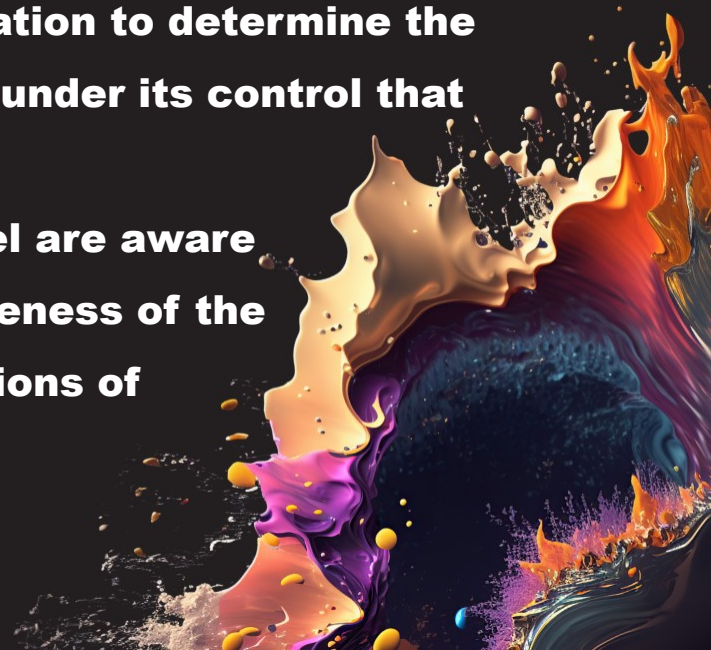


PwnedNext - A OWASP Cornucopia LLM Companion Scenario



ISO 42001:2023

- **Clause 7.2 (Competence):** Requires your organization to determine the necessary competence of all people doing work under its control that affects your AI performance and safety.
- **Clause 7.3 (Awareness):** Mandates that personnel are aware of the AI policy, their contribution to the effectiveness of the AI Management System (AIMS), and the implications of not conforming with AIMS requirements.



ISO 42001:2023

- **A.6.2 (Responsible AI Design and Development): Developers must be trained on how to apply ethical and safe design patterns.**
- **A.6.3 (Verification and Validation): Testers and QA engineers must be trained in AI-specific testing methods.**
- **A.4.2 (Human Resources) mandates that organizations must ensure they have access to adequate human resources with the necessary AI expertise to develop systems safely.**



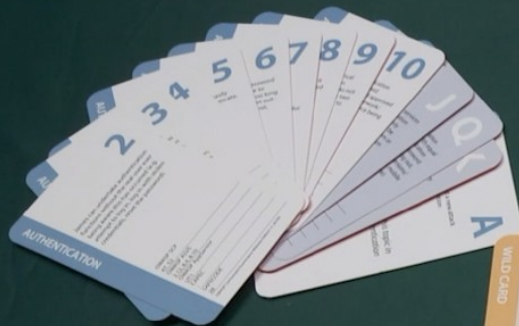
**DON'T GAMBLE WITH YOUR
APPLICATION SECURITY
PLAY CARDS WITH IT**



**THE CARD GAME FOR BUILDING
YOUR THREAT MODEL
[CORNUCOPIA.OWASP.ORG](https://cornucopia.owasp.org)**



Authentication (Spoofing & Repudiation)



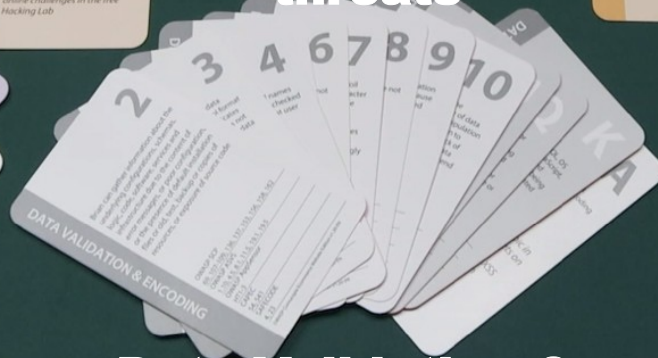
Authorization (Elevation of privilege)



Session Management (All STRIDE categories)



Cryptography (Information Disclosure)



Data Validation & Encoding (Tampering)



Cornucopia

80
potential
threats



copi.owasp.org

Latest updates

Cornucopia Website App Edition v2.2 available >

Threat modelling for everyone everywhere

Uncover the security flaws in your software's design before the bad guys do it for you! Get your team together on a call or in a room and use OWASP Cornucopia Web & Mobile and Elevation of Privilege card decks to guide your threat modelling.

Now you can also secure your AI models by playing Elevation of MLSec or play OWASP Cumulus to secure your Cloud.

Cornucopia Mobile Session: Our Super Mobile App

Hi Pepper Potts, it's round 1

Make sure everyone's

Your Card

CRYPTOGRAPHY

4

Enselme can modify sensitive data (stored or in transit) because it is not subject to integrity checking

OWASP MASVS
CRYPTID-1, CODE-4
OWASP MASTG
TEST-0002
CAPEC
68, 75, 145, 438, 439, 442
SAFECODE
12, 14

0/3

Peter Parker

PLATFORM & CODE

8

Colin can expose sensitive data through the app's interprocess communication because the content provider's query methods are not properly parameterized and arguments sanitized

OWASP MASVS
PLATFORM-1
OWASP MASTG
TEST-0007, TEST-0008
CAPEC
132, 489, 502, 586
SAFECODE

0/3

Susan Storm

PLATFORM & CODE

Grant can m
influencing c
bridges, exte
communicatio
message pa

OWASP MASVS
PLATFORM-1
OWASP MASTG
TEST-0007, TEST-0008
CAPEC
132, 138, 439, 442
SAFECODE



AUTHENTICATION & STOR

Q

Riotaro can inject and run a command that the application will run at a higher privilege level without being authenticated or authorized to do so

AUTHENTICATION & STOR

A

You have invented a new attack against "Authentication & Authorization"

NETWORK & STOR

Bl...
sens...
pass...
cache...
browserboard/clo...
board is not fin...

OWASP Threat Dragon



OWASP Threat Dragon is a free, open-source, cross-platform application for creating threat models. Use it to draw threat modeling diagrams and to identify threats for your system. With an emphasis on flexibility and simplicity it is easily accessible for all types of users.


Login with GitHub


Login to Local Session



Threat Dragon v2.5.0-latest

English ▼

Logged in as local-user



System Gateway->CDN Response:

```
{"fraud_detected": "true" ...}
```

CDN->User Response:

```
{"fraud_detected": "true" ...}
```

Anti-Fraud 2.0



EoP
Games

Threat Dragon v2.5.0-latest

English

Process

Store

Actor

Data Flow

Boundaries

Properties

NameSystem Gateway

Edit Threat #1

Title

New Cornucopia Threat

EoP Games

OWASP Cornucopia

Category

AUTHENTICATION

Status

N/AOpenMitigated

Description

Provide a description for this threat

AT3

AT4

AT5

AT6

AT7

AT8

AT9

ATX

ATJ

ATQ

ATK

ATA

Score

Severity

TBDLowMediumHighCritical

SELECT FROM investig where investiga '927b70bc-da1d-4150-9d

+ New Threat

Adam Shostack's 4 Question Frame for Threat Modeling



1. What are we working on?
2. What can go wrong?
3. What are we going to do about it?
4. Did we do a good job?



<https://github.com/adamshostack/4QuestionFrame>



Values



We have come to value:

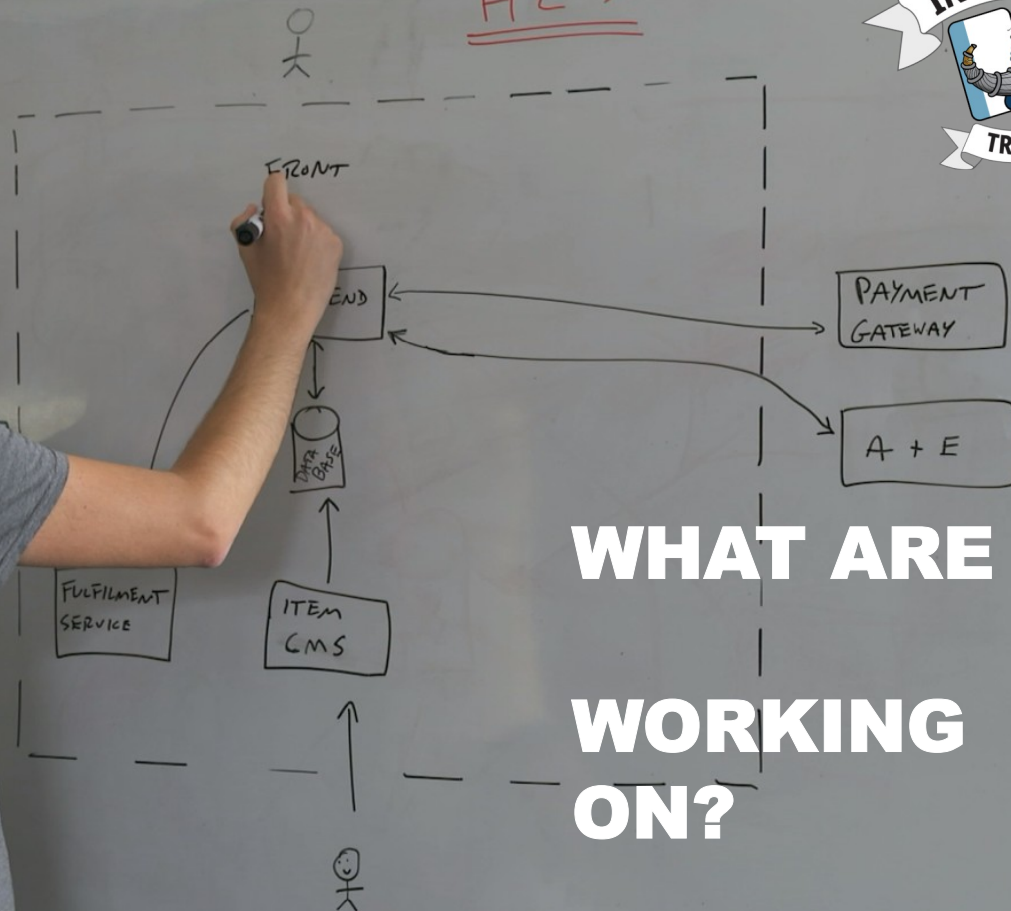
- **A culture of finding and fixing design issues** over checkbox compliance
- **People and collaboration** over processes, methodologues and tools
- **A journey of understanding** over a security or privacy snapshot
- **Doing threat modeling** over talking about it
- **Continuous refinement** over a single delivery



<https://www.threatmodelingmanifesto.org/>

DATA FLOW
DIAGRAM

H L D



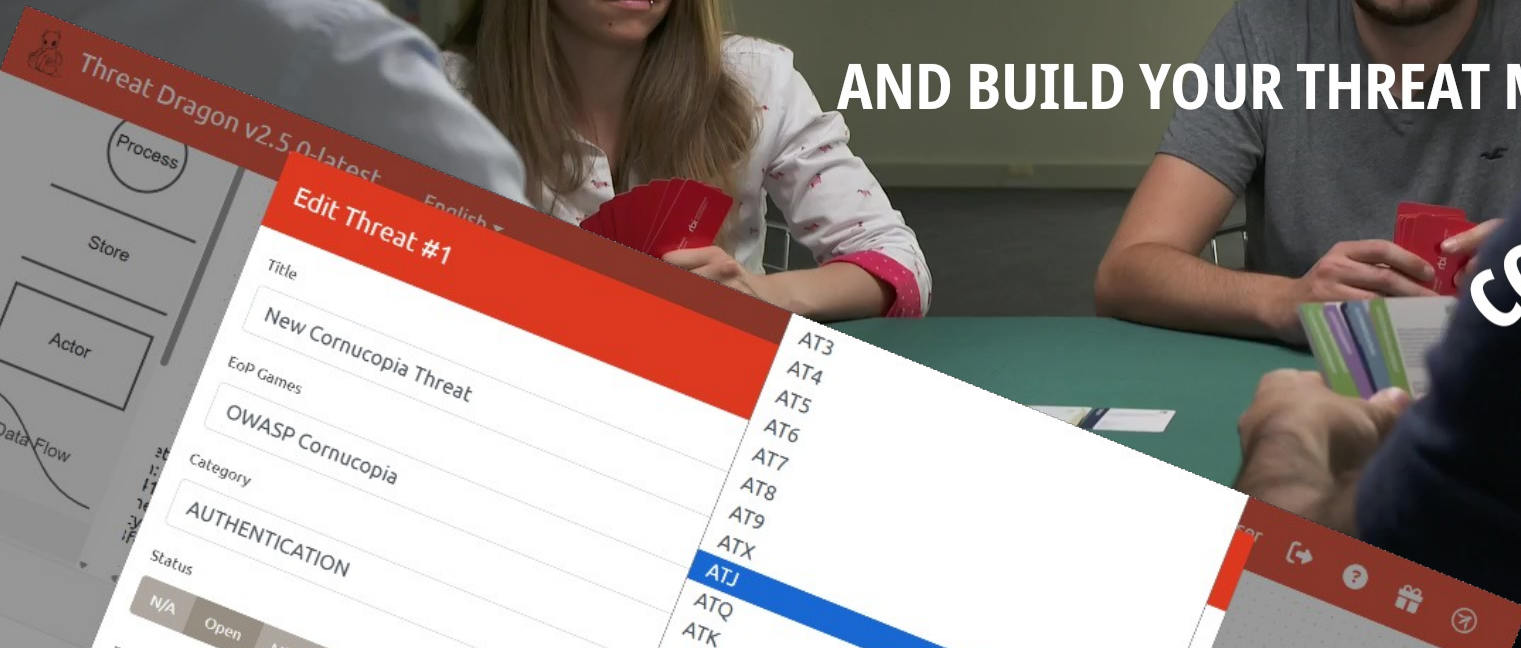
**WHAT ARE WE
WORKING
ON?**

WHAT CAN GO WRONG?

PLAY THE STRONGEST ATTACK,

WIN THE ROUND,

AND BUILD YOUR THREAT MODEL.



Is your security team behaving like Batman?



**Threat Modeling?
That's for security
peopl...**

**Grow a pair and
shift-left you
agile pretender!**



**Breaking news:
PwnedNext buys
F-Corp &
AI Anti-Fraud 3.0**



Cornucopia: 10 Steps



1. The **GM** deals out all the cards
2. The **players** look at the cards and try to **think** which of the **threats** on the **cards** are most likely to be a **real threat** for Anti-Fraud 2.0
3. Cards from the **Cornucopia suit** act as **trumps**. Aces are **high**; the **highest** applicable card **wins** the round. If a **Cornucopia card** is played and applicable, the **highest** Cornucopia card wins
4. To begin the **1st round**, the **player** to the **developer's left** starts the round by **deciding** on a **suit** and **playing** a card with an **applicable** threat, explaining **why**
5. The **players discuss**, and if the players agree it is **applicable**, the player gets a point (**1 point**) If applicable, what does the team want to do about the threat?
Write suggestions down on the **score sheet**!
6. In case of a **disagreement**, the players **vote**. **GM decides** in case of a **tie**
7. The next player **continues playing** a card in the **same suit** until all the players have played.
8. The highest applicable threat card wins the round and gets an extra point (**2 points**)
9. The **winner** starts **next round** by **deciding** on a **suit** and **playing a card**
10. After **all cards** have been **played** or the **allocated time** is **spent**, the player with the **most points wins**!



What you have learned



- **AI Threats, risks, and requirements**
- **How to mitigate AI risks**
- **AI Literacy and Concepts**
- **AI Risk Management**
- **Data Quality Management**





Thank you for coming

